



Q4 • 2021

ThinkstScapes Quarterly

Brought to you by



**Most companies find out way too late
that they've been breached.**

Thinkst Canary changes this.

Canaries deploy in under 4 minutes
and require 0 ongoing admin overhead.

They remain silent until they need to chirp,
and then, you receive that single alert.

When.it.matters.

Find out why some of the smartest security teams
in the world swear by Thinkst Canary.

<https://canary.love>

A road outside Pietermaritzburg, South Africa. Photo by Kiril Dobrev on Unsplash

Contents

Introduction	4
Themes covered in this issue	5
Making servers (over)work for fun and profit	7
Sponge Examples: Energy-Latency Attacks on Neural Networks	8
How to Use Cheated Cryptography to Overload a Server	8
Bestie: Very Practical Searchable Encryption with Forward and Backward Security	9
Analyse and fix	10
Symgrate: A Symbol Recovery Service for ARM Firmware	11
From Graph Queries to Vulnerabilities in Binary Code	12
Fast verified post-quantum software	13
AIModel-Mutator: Finding Vulnerabilities in TensorFlow	14
DAMAS: Control-Data Isolation at Runtime through Dynamic Binary Modification	15
Trojan Source: Invisible Vulnerabilities	16
The AD and Azure beast	17
Who owns your Hybrid Active Directory? Hunting for adversary techniques!	18
Breaking Azure AD joined endpoints in zero-trust environments	19
Bridging gaps and making gaps	20
Going Deeper into Schneider Modicon PAC Security	21
New Ways of IPv6 Scanning	22
DIY cheap gigabit data diode	23
Bridge your service mesh and AWS	24
Nifty sundries	25
GALILEO: In GPS We Trust?	26
"We wait, because we know you." Inside the ransomware negotiation economics.	27
Privacy of DNS-over-HTTPS: Requiem for a dream?	28
Sleight of ARM: Demystifying Intel Houdini	29
Conclusion	30



Introduction

Welcome to the Q4 2021 edition of ThinkstScapes! If you are a returning reader, you'll note that this edition focuses on content presented or published during the end of Q3 and beginning of Q4, as opposed to providing a catch-up on a year's worth of material.

Like the world at large, conferences in this period were influenced by the local pandemic activity and restrictions for in-person events – many in the summer to early autumn in the northern hemisphere were open to some in-person programming, while others were cancelled, and stayed or moved virtual as the Delta variant spread.

During the 3-4 month period leading up to this issue's publication, the number of events was not reduced – almost 300 conferences and thousands of talks and sessions took place. While an impressive number, in returning to a quarterly view, the trends indicators are smaller. In future issues, a “year in review” segment will provide an opportunity to reflect on the identified themes and reevaluate the items that may be signalling broader changes in the space. For this issue however, ThinkScapes editors scoured the 300 conferences and narrowed down the content to a short list, taken from the events listed on the right.

THIS EDITION INCLUDES TALKS DRAWN FROM THE FOLLOWING CONFERENCES:

(listed with the number of presentations)

Conference	Number of talks
HITBSECCONF2021 – Singapore	56
Barbhack	9
Sec-T	24
CornCon: Cyber Things Quad Cities Cybersecurity Conference	35
fwd:cloudsec	30
GrrCON Cyber Security Summit and Hacker Conference	65
Security of Software / Hardware Interfaces	8
Black Hat EU	42
IEEE European Symposium on Security and Privacy	40
BSides Singapore	4
NotPinkCon	17
RomHack	6
ROOTCON	19
ESORICS	71
VB2021	16
DEF CON	72
ShellCon	17
Hacktivity	32
Texas Cyber Summit	45
HITCon	35
NoHatCon	9
Total	652



In response to reader feedback from Q3, we are happy to provide an **email option** to receive a notification for new ThinkstScapes releases. Interested readers can **visit the [ThinkstScapes homepage to sign up](#)**, and to grab a link to the audio version, which is available on most popular podcasting applications.

Themes covered in this issue

MAKING SERVERS (OVER)WORK FOR FUN AND PROFIT

Papers in this theme highlighted both a resurgence into offensive research in asymmetric workload attacks and new ways for servers to offer more security guarantees to their clients. From building on SSL/TLS renegotiation denial-of-service attacks (from a decade ago for more modern cipher suites), to targeting new types of [non-crypto] services, these application/protocol-specific attacks show there is ample surface to explore as more functionality moves to remote services. Finally there is an example of a practical deployment of operating on encrypted data, a step towards fully-homomorphic encryption and the possibility of services operating without full access to sensitive client data.

BRIDGING GAPS AND MAKING GAPS

Research in this theme highlights the difficulties and opportunities with network segmentation between IT and OT, and low-security and high-sensitivity segments. Work on practically scanning IPv6 address space reminds us that there are security considerations in moving to a flatter network where every device is world-routable. This theme shows that there is a shift underway in the network space as components traditionally thought of as isolated are less so, and that some types of isolation may be more feasible than anticipated.

ANALYSE AND FIX

"If you can not measure it, you can not improve it."
– Lord Kelvin. Research in this theme highlights the improvements in tooling and how it allows for the measurement and verification of security properties in critical applications. Ghidra2cpg showed a path towards at-scale static querying of program traits from binaries, whereas AIModel-Mutator showed how to develop fuzzing harnesses targeting the frameworks underpinning AI and ML research. This theme ends with a cautionary note: the Trojan Source work demonstrates how unicode control sequences can be used to introduce vulnerabilities into code that looks correct even to a manual reviewer.

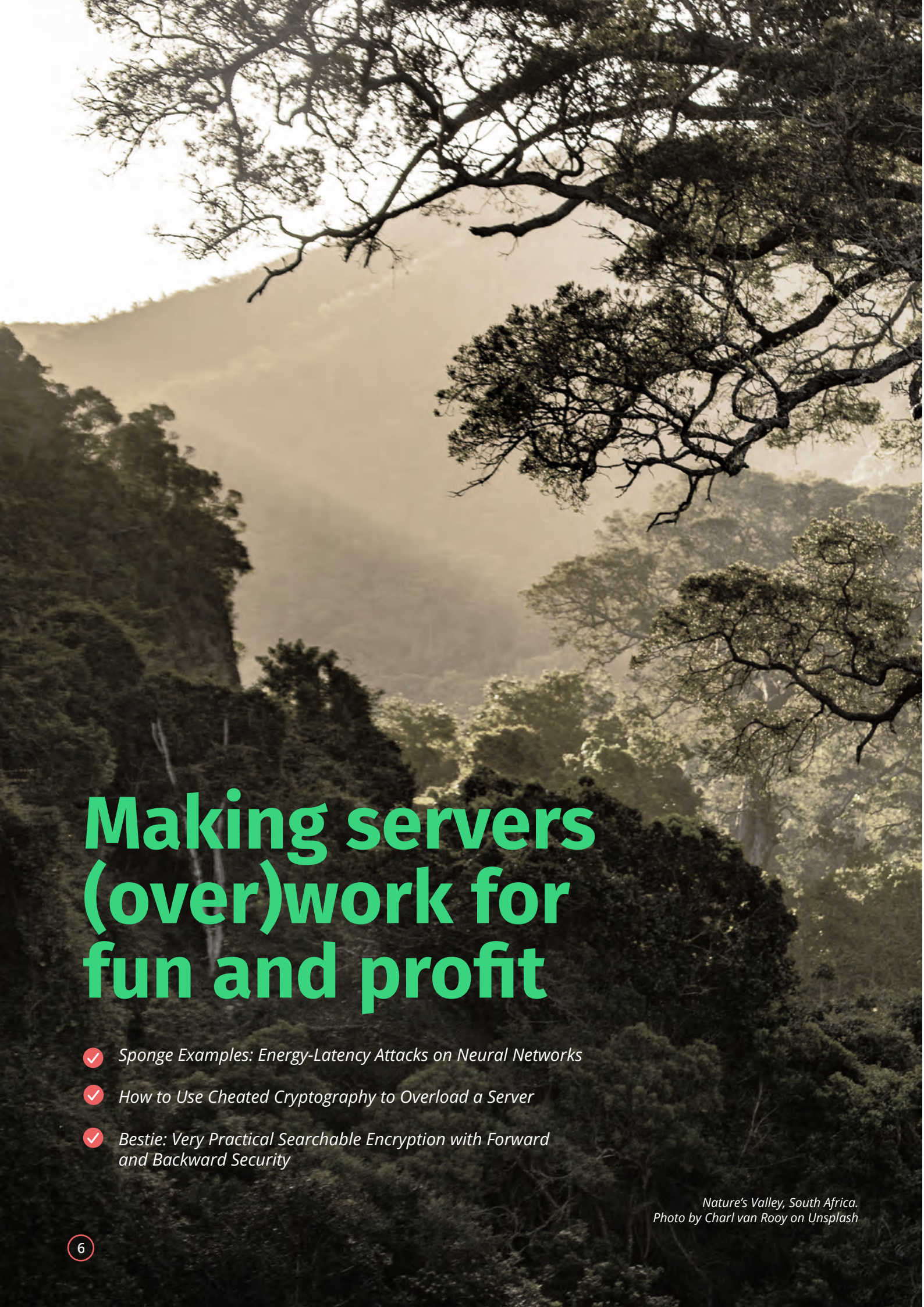
THE AD AND AZURE BEAST

The quantity and quality of work in the specific area of Active Directory attacks, and leveraging the hybrid deployments of cloud and on-premise systems, deserve a theme of their own. There were novel attacks, and foundational research was published this quarter on how the hybrid ecosystem can result in unexpected behaviours that attackers could then make use of.

NIFTY SUNDRIES

As always, there are some papers that do not fit precisely into any emergent theme for the issue, but still warrant inclusion. This quarter includes work on how a trusted location system could enable digital security, how DNS-over-HTTPS can still be subverted for censorship, and how Intel has been supporting emulation of ARM code on its processors and what that means for the Android ecosystem.





Making servers (over)work for fun and profit

- ✓ *Sponge Examples: Energy-Latency Attacks on Neural Networks*
- ✓ *How to Use Cheated Cryptography to Overload a Server*
- ✓ *Bestie: Very Practical Searchable Encryption with Forward and Backward Security*

*Nature's Valley, South Africa.
Photo by Charl van Rooy on Unsplash*

SPONGE EXAMPLES: ENERGY-LATENCY ATTACKS ON NEURAL NETWORKS

Authors: Ilia Shumailov, Yiren Zhao, Daniel Bates, Nicolas Papernot, Robert Mullins, and Ross Anderson



Taking a very different approach to the majority of adversarial AI research, this work looked at generating inputs to a neural network that would cause a drastic increase in processing time and energy consumption. These so-called “sponge examples” attempt to impact the availability of inference services, either as a cloud offering, or as a component in an ML-enabled system. The work looked at both natural language processing (NLP) and image classification tasks, and used genetic algorithms to mutate and optimise sponge examples that would significantly slow down inference tasks or increase energy usage.

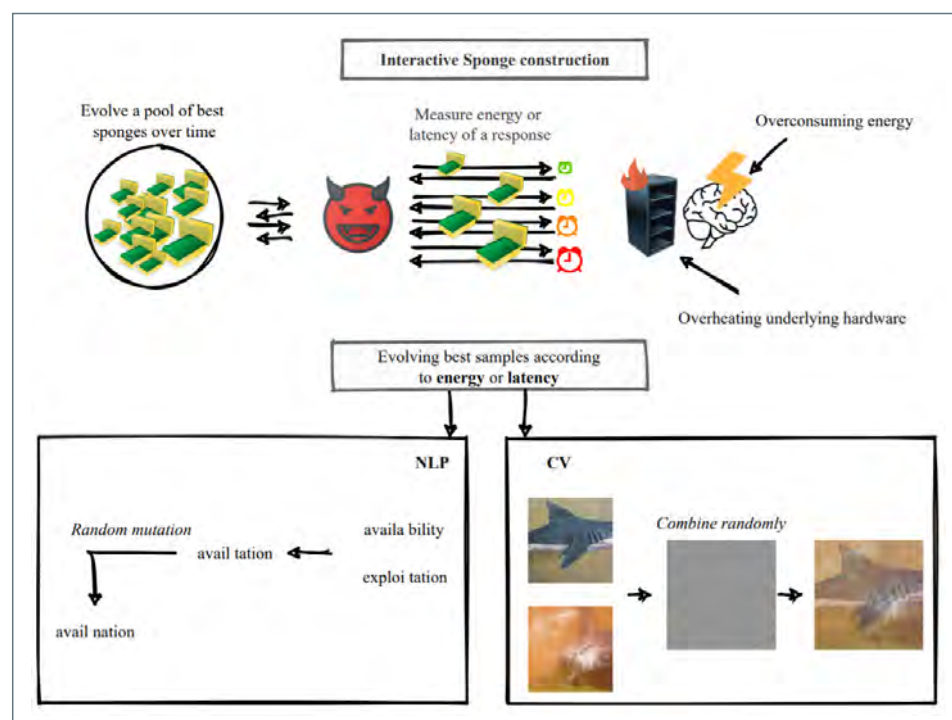
By targeting a specific inference engine in the fitness function of the genetic algorithm, the research demonstrated that benefits from hardware accelerators could be entirely negated, (increasing response latency by up to 6,000 times). By generating nonsense words, NLP tasks could be targeted that would cause additional loop iterations, up to a 27 times slow-down, and 30 times increase in energy consumption.

With cloud inference services billing by usage (either in the number of inference requests or the duration of execution), attackers using these techniques would hit victims squarely in the wallet.

TAKEAWAYS:

- ✓ Adversarial AI/ML is a burgeoning topic, but one without a clear taxonomy of attack classes. As these novel types of attacks (asymmetric workload in this instance) continue to be discovered, a more exhaustive model of the attack surface should solidify.
- ✓ Outside of the cryptography space (see also the following entry on Cheated Cryptography), workload attacks are not often seen in the wild. With the rate of deployment and integration of ML components into complex and safety-relevant systems, it will be interesting to see how a 6,000x latency increase can be handled gracefully in e.g., a self-driving car’s control system.

Figure 1: A figure depicting the workflow of using mutations and genetic methods to develop candidate sponge inputs.



HOW TO USE CHEATED CRYPTOGRAPHY TO OVERLOAD A SERVER

Author: Szilárd Pfeiffer



[View
code](#)

Following in the footsteps of [sslsqueeze](#) and other asymmetric cryptography attacks, the D(HE)ater work presented shows how this class of attack is still valid today (~10 years later). In this class of (D)DoS attacks, the attacker exhausts a server's CPU instead of exhausting their bandwidth or triggering an unhandled exception. A malicious client can attempt to connect to a server over an encrypted link with pre-generated invalid key parameters; the server terminating the link will attempt to perform a key exchange handshake with these bogus values, calculating time-consuming mathematical operations that result in the handshake failing.

The earlier work showed that a used, \$200 laptop (in 2014) could easily generate 20,000 handshakes-per-second. Today, F5's top-of-the-line BIG-IP (over \$100k) can handle at most 80,000 handshakes-per-second, well within striking distance of a modern client PC. This work shows how on mostly modern (< TLS 1.3 or SSH 2.0) servers, a few dozen requests-per-second can redline the server.

TAKEAWAYS:

- ✓ When deploying encryption, the selection and configuration of the cipher suites is important not only to avoid succumbing to export-encryption weaknesses, but also to prevent these types of asymmetric workload attacks.
- ✓ The choice of weak SSL ciphers have long been an inside joke, suggesting a security audit with no real, meaningful findings. It seems those findings may finally prove worth addressing.
- ✓ Encryption is the most common area for these types of attacks to crop up, but there are many other algorithms in the field which have a decent average-time complexity, that become asymptotically slower in the worst case. It will take some time for workload analysis tools and techniques to propagate into the industry.

Figure 2: A table showing the asymmetric workload generation through expensive cryptographic set-up algorithms.

Protocol	Server Implementation	Speed (req/s)	Bandwidth (KB/s)	Effect (+threads)	Efficiency KB/s for +1 thread	Efficiency KB/s for 100% CPU
HTTPS (TLS 1.2)	Apache	~88	~27	~250	~0.10	~6.8
HTTPS (TLS 1.2)	NGINX	~88	~27	0	0	~6.8
SMTP (TLS 1.2)	Postfix	~34	~10	~250	~0.04	n/a
SSH (2.0)	OpenSSH	~52	~320	20-80	~6-25	~80
SSH (2.0)	Tectia SSH	~21	~185	~500	~0.4	~46

BESTIE: VERY PRACTICAL SEARCHABLE ENCRYPTION WITH FORWARD AND BACKWARD SECURITY

Authors: Tuanyang Chen, Peng Xu, Wei Wang, Yubo Zheng, Willy Susilo, and Hai Jin



While efficient fully-homomorphic encryption (FHE; encryption that allows arbitrary computations on its ciphertext) has been a goal for cryptographers since even before Gentry's work in 2008, this research shows the progress on more-narrow, but still useful encryption schemes. Bestie is looking at the problem of performing keyword searches on databases of encrypted documents, where the server, despite doing the majority of the computation, learns nothing about the contents of the documents or the requested keyword. This work takes it one step further, allowing for real deletion, a technique that can guarantee data has been removed (or at least cryptographically-destroyed) by the server – a building block for implementing the GDPR's right to be forgotten. All of this is implemented in an efficient enough manner, making it practical for many applications.

TAKEAWAYS:

- ✓ For many real-world applications, FHE is not needed, and these more use case-specific protocols can allow for more private and secure algorithms in today's distributed environments.
- ✓ The efficiency of Bestie and other role-specific algorithms behaves us as platform consumers and users to demand for these types of techniques to be deployed to better protect us and our data. A policy and corresponding regulation manifested as a technical protocol offers hope that consumers can have more than compliance and PR assurances in the security of their online lives.



The efficiency of Bestie and other role-specific algorithms behaves us as platform consumers and users to demand for these types of techniques to be deployed to better protect us and our data.

Figure 3: A table showing the performance and functionality of Bestie and other comparable encrypted search algorithms.

Scheme	BP	Search cost (μ s)			Round trips	Encryption cost (μ s)	Real deletion
		Client	Server	Total			
Fides [2]	II	4,142.63	24.18	4,166.81	2	4,145.22	Interactive
Mitra [4]	II	5.91	0.53	6.44	2	5.81	Failed
Mitra* [4]	II	12.06	3.92	15.98	2	7.38	Interactive
Diana _{del} [2]	III	82.73/ n_w	11.83	>11.83	2	13.21	Failed
Janus++ [29]	III	480.58/ n_w	154,569	>154,569	1	154,692	Non-interactive
Bestie (ours)	III	0.89	2.77	3.66	2	7.83	Non-interactive



Analyse and fix

- ✓ *Symgrate: A Symbol Recovery Service for ARM Firmware*
- ✓ *From Graph Queries to Vulnerabilities in Binary Code*
- ✓ *Fast verified post-quantum software*
- ✓ *AIModel-Mutator: Finding Vulnerabilities in TensorFlow*
- ✓ *DAMAS: Control-Data Isolation at Runtime through Dynamic Binary Modification*
- ✓ *Trojan Source: Invisible Vulnerabilities*



*A leopard named Tsira in Kruger National Park, South Africa.
Photo by Geran de Klerk on Unsplash*

SYMGRATE: A SYMBOL RECOVERY SERVICE FOR ARM FIRMWARE

Authors: Travis
Goodspeed & EVM



As storage and compute become ever cheaper, it is increasingly feasible to start collecting fuzzy signatures for many large software ecosystems between compilers, compiler versions and even architectures.

Figure 4: A screenshot of Binary Ninja using the Symgrate APIs to identify symbols in a stripped binary.

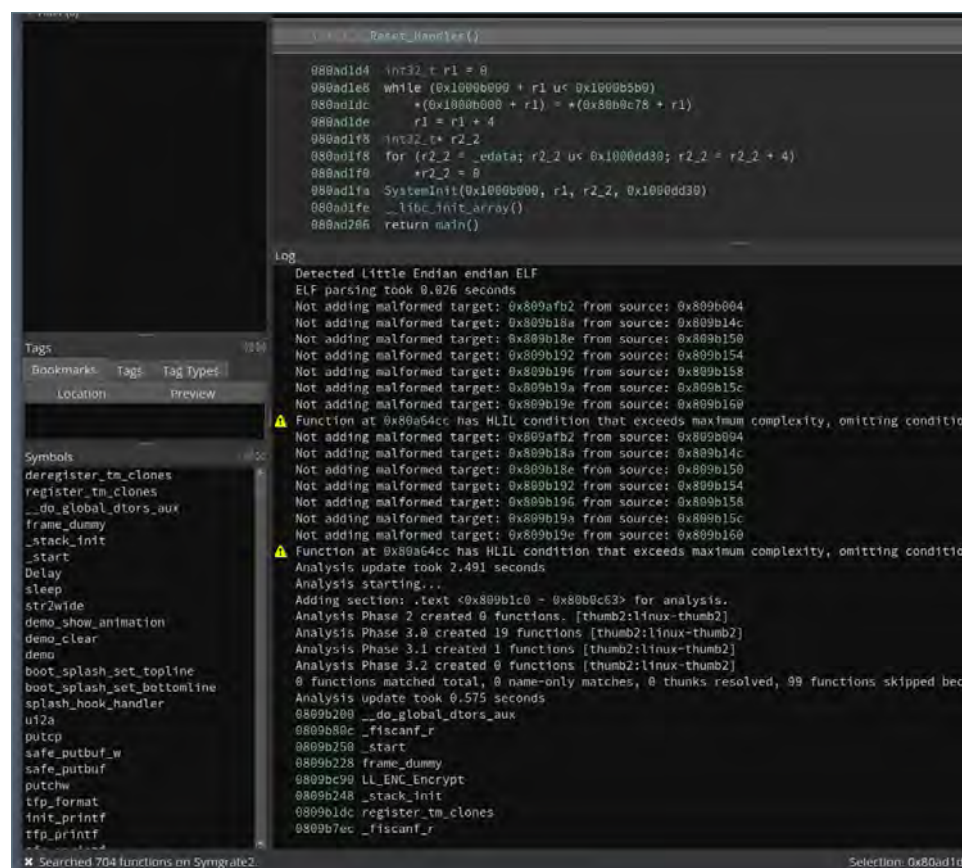
Building on past work in the CTF and reverse engineering communities, this talk aimed to build a simple, API queryable database to allow disassemblers to recover common symbol names. When code is compiled for embedded platforms, typically any human-readable annotations are removed, resulting in a significant amount of semantic loss. Symgrate collects the common functions and methods from a variety of embedded system ecosystems and SDKs, and provides the ability to find them based on the initial few instructions of a function entry point.

This research removes the manual effort needed to identify and label functions in a large embedded binary, providing reverse engineers the ability to focus on the functionality of interest. As seen in the survey of reverse engineers and vulnerability researchers from

the previous ThinkstScapes issue, the first step for either discipline is target understanding, and building a high-level model for how the binary is organised and where components of interest are in relation to the common boilerplate.

TAKEAWAY:

- ✓ As storage and compute become ever cheaper, it is increasingly feasible to start collecting fuzzy signatures for many large software ecosystems between compilers, compiler versions and even architectures. With APIs like these expanding their coverage and analysis tools becoming better able to homogenise between source and binaries, any protections offered by binary distribution of software will disappear.



FROM GRAPH QUERIES TO VULNERABILITIES IN BINARY CODE

Authors: Claudiu-Vlad Ursache, Fabian Yamaguchi, and Niko Schmidt



This research talk provided a snapshot into the progress of using static Code Property Graph (CPG) analysis on binary code. CPG analysis combines a control-flow graph, data-flow graph, and abstract syntax tree into a language-agnostic representation of a program. This graph can be queried for e.g., unchecked data flows to a database query function, or unsafe memory operations with arguments from user input. A benefit of this type of analysis is that a concise description of a vulnerability class (e.g., integer operations used as a size for a call to malloc) can be codified, shared, and then searched for (at scale) across multiple languages and complex, multi-component software systems.

A follow-up to a previous attempt ([bjoern](#)), this more successful work used Ghidra's decompiler to recover the semantics lost during compilation. While there is still some information missing, the researchers were able to use existing vulnerability queries designed for source to find vulnerabilities in a binary image with minimal modification.

Looking at the firmware image for a Wi-Fi router and its embedded web administration server, multiple RCE vulnerabilities were found, as well as ROP gadgets to use for specific attack functionality.

TAKEAWAYS:

- ✓ As the semantic gap between analysis of source and binaries continues to diminish, tooling designed for CI/CD pipelines can be retargeted at binaries. While the knowledge of vulnerabilities in the supply chain may not directly allow for mitigation, it should allow for better purchasing decisions and drive improvements in the entire ecosystem (a thesis explored by the Zatkos' Cyber-ITL).
- ✓ As an open-source option for reasoning on source and binaries, joern can kick-start automation and tooling to leverage these analysis techniques and knowledge-sharing of vulnerability patterns.

Figure 5: An overview of the talk's main contributions.

Ghidra2cpg

- Joern frontend that imports Ghidra disassemblies into Joern initiated by Niko
- Goal: Joern but for code that we are not supposed to analyze => **polynomial-time interprocedural data flow analysis for binary as a key feature**
- More and more steps taken these days to include information from the decompiler
- Still under (open) development - this project is its first larger test drive

FAST VERIFIED POST-QUANTUM SOFTWARE

Author: Daniel J. Bernstein



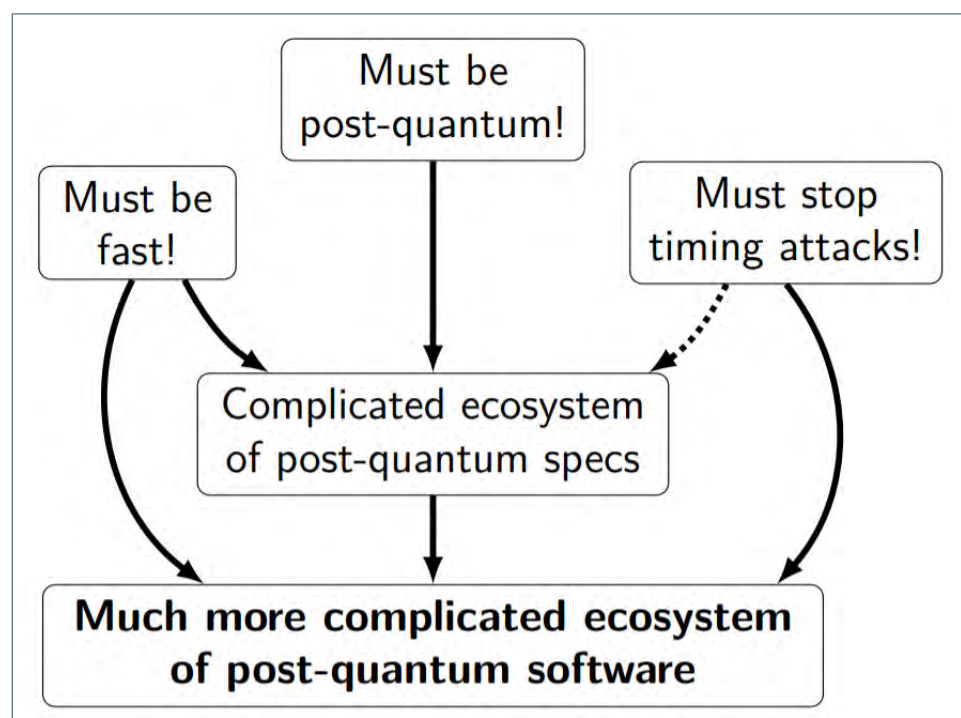
This work looks at using symbolic analysis tools and techniques to verify compliance between a reference implementation and an optimised, architecturally targeted, or differently compiled output. The author notes a growing trend in the complexity of cryptography software, especially in support of post-quantum algorithms. In order to prevent inadvertently “rolling your own crypto”, the tool “saferewrite” is introduced to verify equality between a reference implementation and subsequent specific modifications.

With the focus on cryptography software, saferewrite goes beyond semantic equivalence of the algorithm, also taking into account any timing differences that could act as a side channel to leak sensitive data. Building on Valgrind, angr, and Z3, the open-source saferewrite tool is quick to execute even on complex and architecturally-optimised code (e.g., using a hardware acceleration component).

TAKEAWAYS:

- ✓ While initially focused on cryptographic algorithms, the model of using an agreed-upon reference implementation and verifying other derivative variants is a powerful model to reduce the prevalence of parser differentials. (There has been a long history of different implementations of the same protocol or file format interpreting input differently, leading to security problems later, e.g., Mozilla Firefox’s X.509 certificate parser bug).
- ✓ The tools upon which saferewrite is built are mature and have strong communities. With a small investment in tailoring these to the specific needs of the software, micro-verification tasks can be embedded into the CI/CD pipelines for a number of projects, preventing accidental or malicious insertion of errors.

Figure 6: A figure illustrating the pressures to add complexity which results in the cryptographic security failures that saferewrite aims to detect.



AIMODEL-MUTATOR: FINDING VULNERABILITIES IN TENSORFLOW

Authors: Qian Feng, Zhaofeng Chen, Zhenyu Zhong, Yakun Zhang, Ying Wang, Zheng Huang, Kang Li, Jie Hu, and Heng Yin



This research looked at the attack surface of TensorFlow from the perspective of an untrusted model. Typically, ML developers will use an existing model and refine or improve it to suit their specific needs. The researchers looked at the possibility of a malformed model (Keras) file exploiting the TensorFlow engine itself. By using protocol-aware fuzzing techniques and extracting constraints from how NNs are designed, the researchers discovered and reported multiple CVEs in the underlying C/C++ code of TensorFlow.

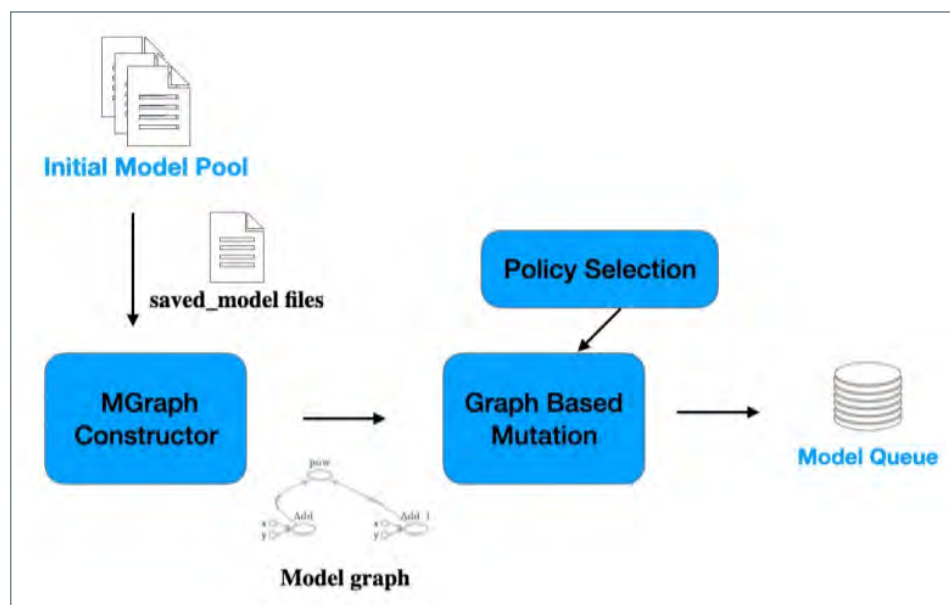
The bulk of this work is understanding and encoding the constraints of a valid NN layout to get coverage deeper into the TensorFlow stack; random mutations will generally result in rejected input files and little to no surface coverage. In the slides, the researchers present the various structure types and sizing/rank constraints, and how some assumptions can be violated when

the model is executed and parsed. While the discovered vulnerabilities do not appear to allow for code execution (majority are OOB reads or null pointer dereferences), the work highlights a risk to the standard workflow in ML of downloading and ingesting untrusted models to build on top of.

TAKEAWAY:

- ✓ The field of adversarial AI has primarily focused on models that can be subverted, or have subtle weaknesses embedded in them to provide incorrect responses to input. It has not focused on how a model can act as a stepping stone for more traditional memory corruption vulnerabilities. Underlying all the Python code is C/C++ processing mostly untrusted inputs – as this work highlights, more thought is needed prior to loading a model found on the internet.

Figure 7: A figure showing how candidate models were generated to fuzz TensorFlow.



DAMAS: CONTROL-DATA ISOLATION AT RUNTIME THROUGH DYNAMIC BINARY MODIFICATION

Authors: Camille Le Bon, Erven Rohou, Frederic Tronel, and Guillaume Hiet



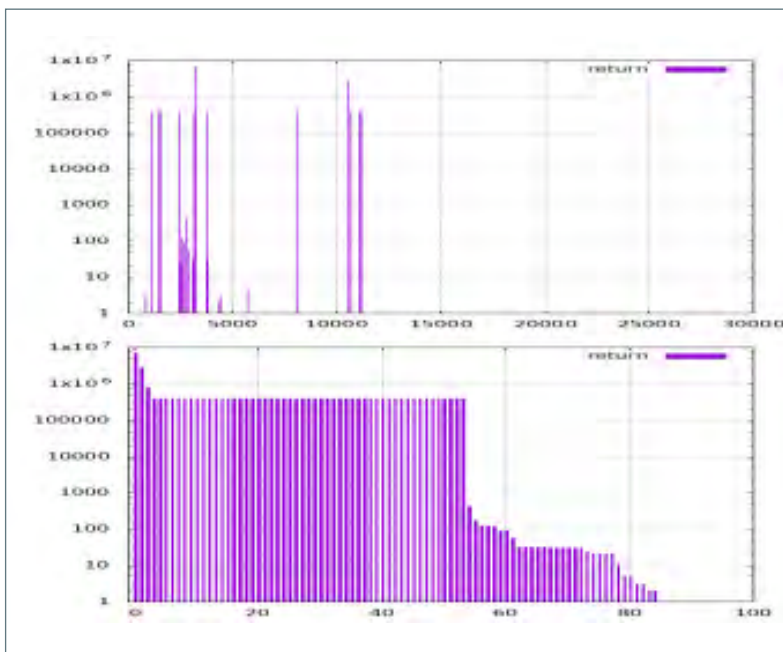
This research aims to identify the largest subset of modern control-flow integrity defences that can be safely applied without source access, and evaluated the performance impacts of a naive and optimised implementation. DAMAS removes indirect branches from running binaries in memory by identifying all indirect branches (calls, jumps and returns), and building a dispatch table for each to permissible targets. For example, a return should only target an instruction directly following a call, whereas a call should only target the beginning of a function. Each dispatch table checks the indirect target to ensure it is in the permissible set before using a direct branch to that target.

A naive approach implements significant performance overhead due to the over-approximation needed, and therefore on each indirect branch, a long table must be walked. DAMAS

explores runtime optimisation by profiling the targets executed, and, if there is a significant difference between the most-used and the average, it rearranges the table. Otherwise, a binary tree is used to decrease the table traverse time.

Evaluating the optimising DAMAS on CPU-bound programs showed a 9-19% overhead introduction, whereas on IO-bound programs (server daemons) the overhead shrank to between negligible to 4%. On the security side, the over-approximation needed to ensure safe application to a binary does allow some attacks to persist, such as a call-to-libc, which is a valid entry point. With more exhaustive exercising of the program, or better CFG recovery, both the security and performance can be improved.

Figure 8: A figure depicting the call targets of SQLite3 unsorted (top), and sorted (bottom). Note the differing X axes.



TAKEAWAYS:

- ✓ While there are engineering limitations, DAMAS shows that the last excuse preventing deployment of more modern binary hardening (it's already deployed, or source is not available) doesn't hold water anymore. Especially for IO-bound processes, a runtime mitigation that optimises over time for the usage of the protected process means even legacy applications can be protected.
- ✓ Significant data is lost during compilation that acts as a "one-way door" and lessens the ability for defenders to implement fine-grained enforcement. While open-source software's claim that many eyes find many bugs may be questionable, the ability to recompile with state-of-the-art protections is an unquestionable benefit which is seldom discussed.



TROJAN SOURCE: INVISIBLE VULNERABILITIES

Authors: Nicholas Boucher and Ross Anderson



[Read Paper](#)



[View code](#)

This research builds on the past work of using the differences between the machine-readable content and the human-visible render of Unicode to create a template of attacks where the source appears legitimate but actually compiles or interprets maliciously. Where previous works have primarily focused on using non-Latin characters that look the same as their Latin counterparts (e.g., an 'x' and a cyrillic 'x'), this research explores using Unicode's support for both right-to-left and left-to-right languages to change the ordering of tokens. As an example in the Figure below, adding an unbalanced change (indicated with the RLI token) will move the return outside of the comment when the code is interpreted, allowing a malicious commit to skip certain statements.

In addition to the past work, this research highlights the challenges of protecting open-source codebases from malicious attacks from a motivated and surreptitious adversary. If a project enforced a code review prior

to accepting the pull request, it would be very difficult to ensure the code did not introduce any subtle weaknesses. While there are proposed (and partially adopted) fixes throughout the CI/CD ecosystem for this specific attack, it speaks to the need for deeper automated analysis in an environment which closely matches that of deployment.

TAKEAWAYS:

- ✓ As evidenced by the controversial [UMN Linux Kernel research](#), even very high-profile open-source projects can miss non-obfuscated weaknesses introduced to the source tree.
- ✓ Tools like joern, CodeQL and other personalisable static analysis tools can be brought online to express some of the guardrails of how code should behave in order to automatically evaluate new code for malicious or accidental violations.



As an example in the Figure below, adding an unbalanced change (indicated with the RLI token) will move the return outside of the comment when the code is interpreted, allowing a malicious commit to skip certain statements.

<pre>#!/usr/bin/env python3 bank = { 'alice': 100 } def subtract_funds(account: str, amount: int): ''' Subtract funds from bank account then RLI''' ;return bank[account] -= amount return</pre>	<pre>#!/usr/bin/env python3 bank = { 'alice': 100 } def subtract_funds(account: str, amount: int): ''' Subtract funds from bank account then return; ''' bank[account] -= amount return</pre>
---	--

Figure 9: The same Python snippet showing the interpreted source on the left, with the rendered source on the right.

The AD and Azure beast



- ✓ *Who owns your Hybrid Active Directory? Hunting for adversary techniques!*
- ✓ *Breaking Azure AD joined endpoints in zero-trust environments*

*Breakers Resort, Umhlanga, South Africa.
Photo by Kyle Frederick on Unsplash*

WHO OWNS YOUR HYBRID ACTIVE DIRECTORY? HUNTING FOR ADVERSARY TECHNIQUES!

Authors: Thirumalai Natarajan Muthiah and Anurag Khanna



This paper is aimed squarely at Blue Teamers looking to expand their knowledge and understanding of Azure persistence techniques. The work is narrow but Azure AD is a significant part of modern enterprise identity management. Malicious Azure applications have become a go-to vector for phishers to infiltrate Office 365, as they aren't detectable by endpoint security products.

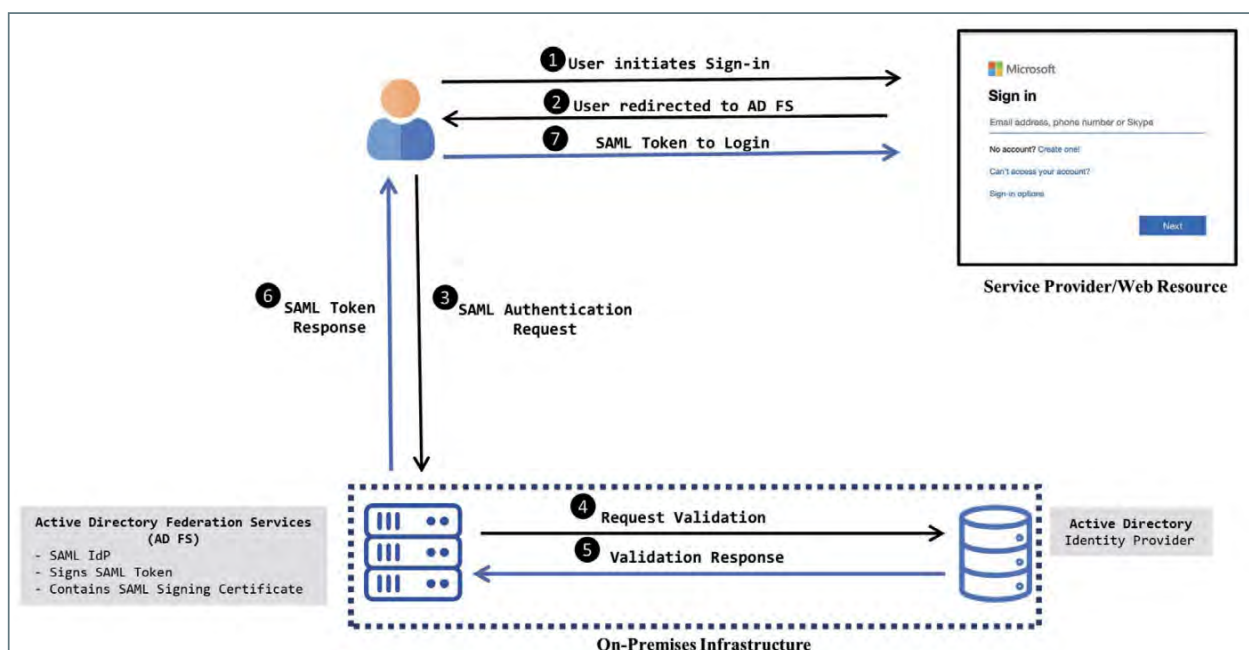
Less well known are techniques for attackers to achieve persistence inside of victim Azure organisations via Azure Applications; identity federation between Azure AD and external identity providers; and backdooring pass-through authentication. Each of these is quite different, but provides attackers with long-term persistent access with low probability of discovery. The authors walk through how an attacker can leverage these in malicious ways.

The paper's Blue Team usefulness is elevated by providing concrete detection and hunting techniques for each of the three areas of security exposure.

TAKEAWAYS:

- ✓ Azure layers on even more complexity on top of an already unmanageably complex Active Directory. The outsourcing of AD to the Cloud promises operational simplicity but it comes at the price of increased code complexity (and therefore risk).
- ✓ The disparity between the persistence techniques suggests further options are waiting to be explored.
- ✓ Blue Teams should be conducting regular threat hunting exercises in Azure, as these techniques are only identifiable post the event from logs.

Figure 10: Abusing AD Federation Services with a malicious federated domain.



BREAKING AZURE AD JOINED ENDPOINTS IN ZERO-TRUST ENVIRONMENTS

Author: Dirk-jan Mollema



View
Slides



Watch Video

On-premise Active Directory has proved to be almost impossible to secure without incredible investments in skills and attention. The introduction of Azure AD has reduced IT's headaches in many instances, by largely relying on Microsoft's skills in running the infrastructure part of AD. But Azure AD comes with a new security model that may not be fully understood.

This talk focuses exclusively on Azure AD, which provides the identity services for a range of Microsoft products including Office 365, Azure and third parties. In other words, the techniques shown in the talk subvert the identity service that underpins multiple business critical applications.

The author provides background on how devices are registered into Azure AD and what this flow looks like under the hood. He introduces the Primary Refresh Token (PRT) as a central resource for Azure AD authentication to provide SSO abilities to apps in the user session, and shows how cryptographic key material is stored within TPMs whenever possible.

He demonstrates an attack that lets an attacker leverage the PRT on a compromised host to sign into a site that uses the victim's Azure AD SSO (e.g., the company's Outlook service). In simple terms, if a victim is phished and an attacker gains remote execution in their user session, then an attacker can access any SSO-enabled service open to the victim even if the victim hasn't

logged into that service recently, through the use of the PRT. The attack does not require Administrator privileges.

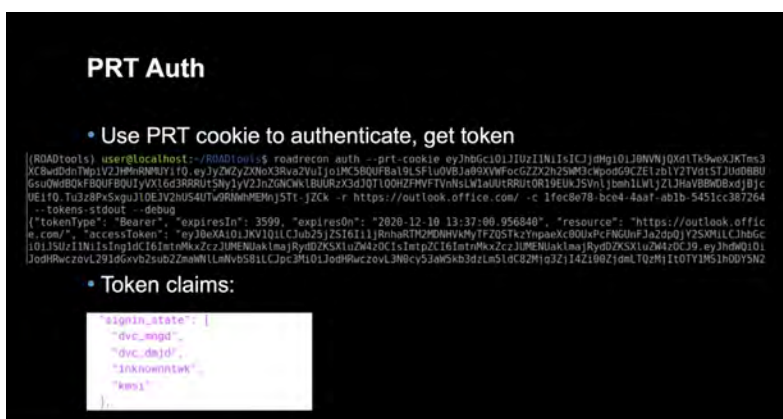
He demonstrated a further attack that does require Administrator privileges: by working with Benjamin Delpy to extend Mimikatz to extract PRTs (or a PRT-equivalent token when TPMs are present) from all users on a machine. This involved understanding the signing flow used by Azure AD on local machines, and implementing that in Mimikatz.

The last attack demonstrated took one final leap. Device objects are a core part of Azure AD, separate from user objects. And a device object is a very useful thing to have since they lead to PRTs. So he built tooling that would allow an attacker who has compromised a user's machine (e.g., via phishing) to register additional fake devices into the Azure AD. This is dependent on user-permissions, but does not require full Administrator permissions. If the user had an MFA check already performed, then the newly registered device and its PRT would inherit the same "OK" status, and not require MFA confirmation! This gives long term persistence in Azure AD, even if a device is wiped.

TAKEAWAYS:

- ✓ Azure AD's apparent simplicity belies new functionality that is still being pulled apart. This early work sheds light on the information flows that underpin Azure AD.
- ✓ As a result of this work, Microsoft has revamped its Azure AD and patched some of these attacks. The risks have mostly been mitigated already.
- ✓ The broader point remains that AD is still a mighty complex beast, and merely outsourcing its management to Microsoft is no guarantee that all the angles are covered. We expect further attacks to emerge.

Figure 11: PRT attack lets an attacker pivot to SSO-enabled services.



Bridging gaps and making gaps

- ✓ *Going Deeper into Schneider Modicon PAC Security*
- ✓ *New Ways of IPv6 Scanning*
- ✓ *DIY cheap gigabit data diode*
- ✓ *Bridge your service mesh and AWS*



GOING DEEPER INTO SCHNEIDER MODICON PAC SECURITY

Author: Gao Jian



The increased functionality of fully-programmable PACs versus the limited PLCs brings with it a host of security concerns to safety and business critical environments.

Figure 12: A figure showing a demo setup using boofuzz to trigger a remote DoS on the Modicon PAC.

This work examines the security of Programmable Automation Controllers (PACs), a step up in industrial automation from Programmable Logic Controllers (PLCs) in that they support more complex programming logic, and provide additional monitoring capabilities. PLCs have been a mainstay of the ICS/SCADA world for controlling automated processes, especially in safety or business critical operational environments. PACs bring increased capabilities including web and FTP servers, and enhanced programmability in more common programming languages such as C/C++. Due to ICS' patchy security record, security is a core feature of PACs, including password authentication and signature validation of software being loaded.

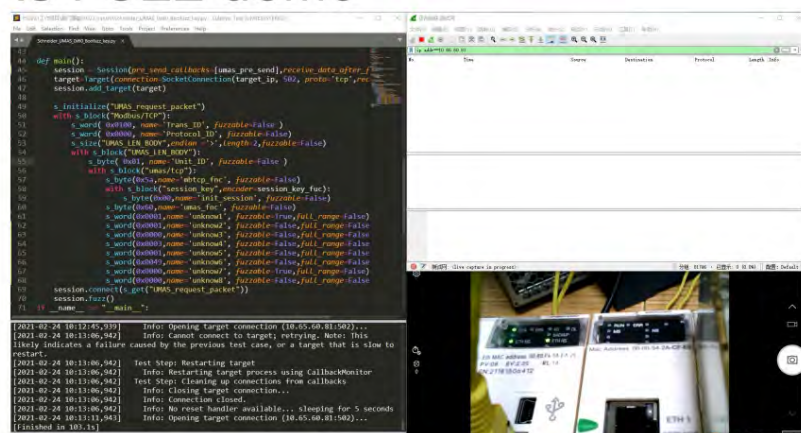
The researcher explores those claims through a hybrid of RE, protocol fuzzing and analysis of the custom management protocol. Many of the proprietary commands to manage the PAC do not require authentication, allowing for memory reading to find a replayable password hash. This allows for authentication to the PAC, and a

bypass on the integrity verification of the loaded code, letting a malicious program hijack function pointers via arbitrary memory reads/writes. In sum, all of the claims of additional protection paired with these more powerful controllers were subverted.

TAKEAWAYS:

- ✓ The increased functionality of fully-programmable PACs versus the limited PLCs brings with it a host of security concerns to safety and business critical environments. Their deployment should be carefully considered and treated more like an IoT device as opposed to a restricted OT component.
- ✓ Inviting process engineers and ICS architects to develop complex distributed automation in C/C++ versus constrained and verifiable ladder-logic seems like a concerning jump in an otherwise conservative industry with an already poor security record.

UMAS FUZZ demo



A demo for a successful DOS Vulnerability using the FUZZ tool under just 100 s



NEW WAYS OF IPV6 SCANNING

Authors: Shupeng Gao,
Xingru Wu, and Jie Gao



This work looked at the premise of scanning IPv6, which on the face of it is intractable due to the sheer size of the address space. However, these researchers discovered that there were a number of weaknesses, both technical and configuration-based, which allowed them to map significant numbers of IPv6 clients. Focusing primarily on 4/5G mobile network connected devices, the researchers highlighted five issues (see Figure) including: where ICMP responses would leak half of the address, having access to the local network would allow calculation of the WAN IPv6 address, and a reduction in the search space by limiting the bits used in address generation.

This work coupled with an understanding of how certain ISPs assign prefixes (telco, region, city, etc.) allowed for a quick search for all Android devices connected to a certain provider in a specific city. While a number of targets for these findings

needed to be in hotspot mode, Android devices worked without any such requirements, providing ample targets for an attacker. Many of the identified risks are not considered vulnerabilities by the vendors (despite the lack of scanning acting as a security benefit) and thus will not be remediated on the device level.

TAKEAWAYS:

- ✓ IPv6 requires dedicated thought to deploy and use securely, with the world on IPv4 NAT'd networks for so long, there is a mindset shift needed to migrate to an externally-routable network posture.
- ✓ Zmap and Masscan provided the ability to scan the majority of the IPv4 internet in a short time – with the techniques disclosed in this research, scanning significant portions of IPv6 may become feasible, putting more unhardened devices into attackers' sights.

Figure 13: A table summarising the issues discovered in IPv6 address allocation and ICMP handling that allow for tractable scanning.

	Risk	Scan world-wide	Android	IOS	Linux	Windows
Risk 1	ICMP unreadable error return the full addr	Y	✓			✓ Hotspot
Risk 2	In some cases the IPv6 addr will become shorter	Y	✓ Hotspot			
Risk 3	IPv6 addr can be sniffed and calculated from radio nearby	N	✓			
Risk 4	ICMP time exceeded error returned the full addr (all Linux kernel based devices)	Y	✓ Hotspot	✓ Hotspot	✓ Hotspot or Forward	✓ Hotspot or Forward
Risk 5	All zero address returned the full addr (all Linux kernel based devices)	Y	✓ Hotspot		✓ Hotspot or Forward	

Hotspot = need hotspot function enable. Hotspot will enable IPv4/6 forward

Forward = need net.ipv6.conf.all.forwarding = 1. In the routing device, it is a default configuration

DIY CHEAP GIGABIT DATA DIODE

Author: Magnus



[View code](#)

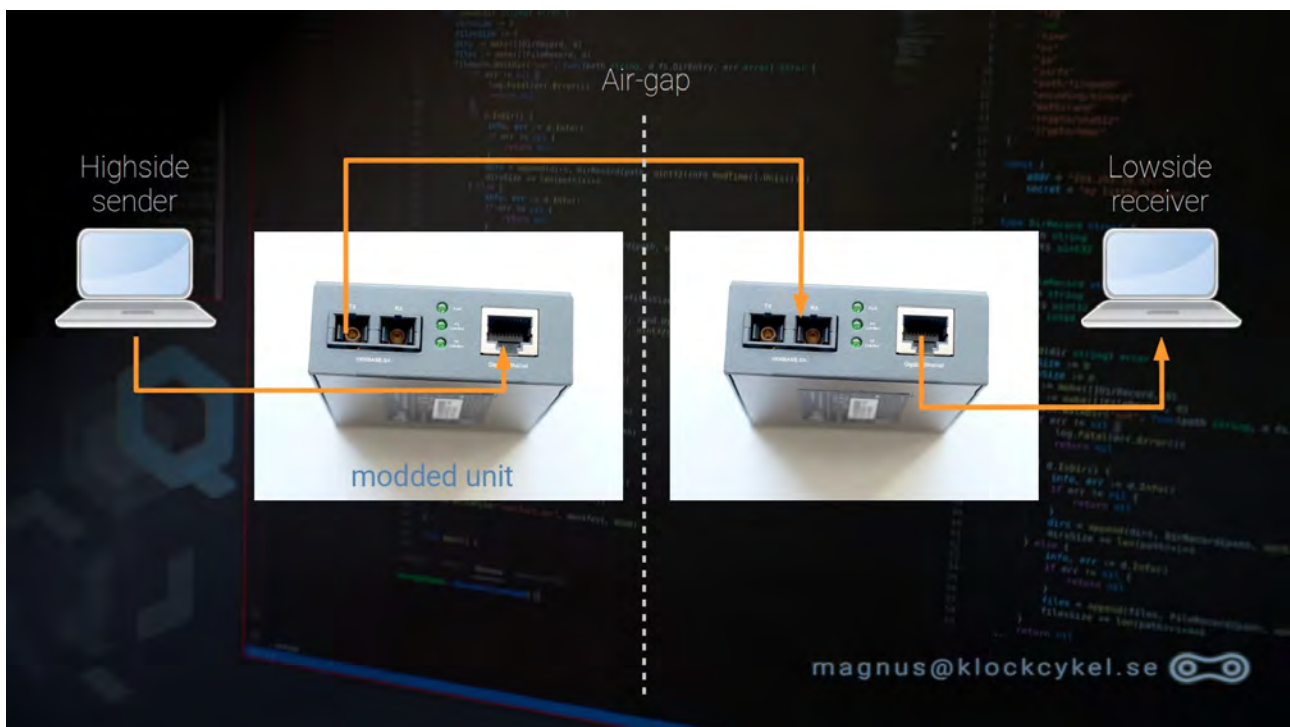
While not a new concept, data diodes allow for a physical guarantee of network segregation. They are most commonly found in Government networks as a way to upload data to a classified network without risk of a leak from a more sensitive network to a less sensitive one. While it is possible through network ACL configuration to replicate the behaviour, these diodes physically cannot transmit in reverse, whereas an ACL-based solution could be accidentally or maliciously deactivated. Being a niche market (vendors charge thousands of dollars for a diode solution) this research looked at repurposing a pair of optical media converters to create a gigabit speed diode for approximately \$50. The work includes the physical changes needed to allow the converters to operate unidirectionally as well as a file transfer program to send data over the diode

without expecting a response or ACK as is expected in most protocols (and essential for even a TCP handshake to complete).

TAKEAWAYS:

- ✓ Rarely seen outside of Government spheres, data diodes allow for unidirectional data transfer. By dropping the price of these from thousands of dollars to ~\$50, more networks can add this asymmetry to isolate e.g., backups from even the most deeply entrenched attackers.
- ✓ Network segmentation can add a burden to an attacker trying to move laterally. Air-gaps and unidirectional gaps can take that one step further, putting a significant onus on the attacker.

Figure 14: A figure demonstrating how to use low-cost fibre media converters to create a network diode.



BRIDGE YOUR SERVICE MESH AND AWS

Authors: Santosh Ananthakrishnan and Harihara K Narayanan



This talk covered a very specific implementation at Square that allows their service mesh to operate seamlessly with AWS. In part we have included it because we are huge fans of Square's philosophy where security teams build infrastructure that is adopted by internal teams.

The talk also gives good insight into what a modern, cloud-native network

looks like (along with some of the new challenges they bring).

Years ago we covered the Square team's discussion on Crypto-Anchors and even then were impressed primarily by the approach where the security team built tooling that was then willingly adopted by internal teams (as opposed to security simply acting as a blocker). This talk shows that philosophy endures.



The talk gives good insight into what a modern, cloud-native network looks like (along with some of the new challenges they bring).

TAKEAWAYS:

- ✓ Building easy to use, secure, internal tooling is a high leverage technique to get internal teams doing the right thing;
- ✓ Computing environments of cloud-native companies look very different to traditional networks. Red-teamers and offensive researchers would do well to immerse themselves in this new world.

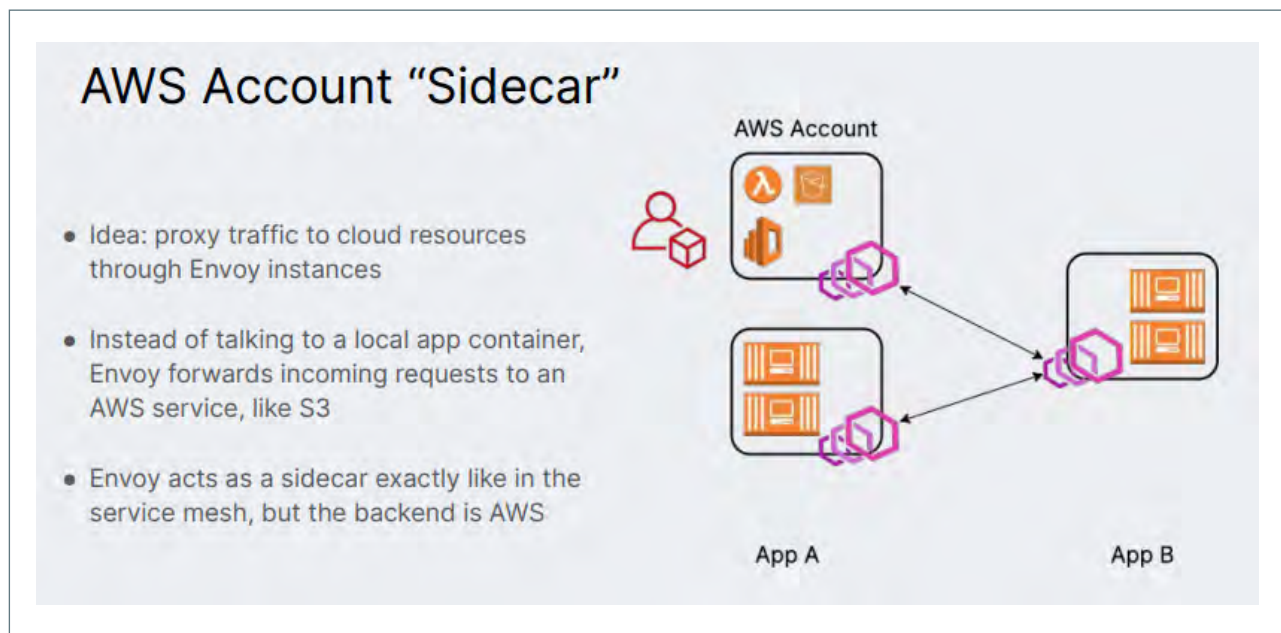


Figure 15: Using Envoy to proxy access to AWS resources.

Nifty sundries

- ✓ *GALILEO: In GPS We Trust?*
- ✓ *"We wait, because we know you." Inside the ransomware negotiation economics.*
- ✓ *Privacy of DNS-over-HTTPS: Requiem for a dream?*
- ✓ *Sleight of ARM: Demystifying Intel Houdini*



*Giraffes in Kruger National Park.
Photo by Tobin Rogers on Unsplash*

GALILEO: IN GPS WE TRUST?

Authors: Áron Szabó,
Levente Kovács, and
Péter Ligeti



After laying out some of the notable public attacks on GPS, this work describes a higher security function in the European GALILEO location service. While the other global navigation services offer higher resolution and protection to their military users via an encrypted stream, GALILEO is unique in that it offers a public-key-authenticated signal (OSNMA) for non-military users.

The work goes on to explore the hypothetical features a strong, trusted location could provide. By tying digital communications to a known physical location, the location can become part of a MFA authentication handshake or provide greater confidence in self-driving vehicles. Unfortunately, while this capability was introduced into the constellation in 2016, it is still not in the production signal. Even if it were, HW and SW support is extremely limited, and not built in such a way to seamlessly support the proposed use-cases.

TAKEAWAYS:

- ✓ As the internet of things continues to take hold, combining autonomous sensors, vehicles, and devices, a high-confidence location can act as a root-of-trust in various communication protocols.
- ✓ Even with an improved capability, there is limited support, and by the time that support has proliferated, there will likely be new attacks that reduce its efficacy.
- ✓ Galileo has had high-profile failures in the past, in which even the fail-safes were unable to compensate, providing incorrect location data to users. The response to this latest outage was to clarify that the system is still not ready for production use. Third parties may be reluctant to build on the OSNMA capability without a history of reliable support.

Figure 16: A table comparing the protections in place between the different GNSS options.

GNSS	GPS	GLONASS	BeiDou	GALILEO
origin country	US	RU	CN	EU
protected data	location date/time	location date/time	location date/time	location date/time
type of applied cryptography	symmetric	symmetric	symmetric	symmetric asymmetric
protected data is available to	military service	military service	military service	military service civilian service
protects against	spoofing (limited)	spoofing (limited)	spoofing (limited)	spoofing (unlimited)

“WE WAIT, BECAUSE WE KNOW YOU.” INSIDE THE RANSOMWARE NEGOTIATION ECONOMICS.

Authors: Pepijn Hack
and Harihara K
Narayanan



This paper by the Fox-IT team at NCC analysed over 700 ransomware negotiations between 2019 and 2021 with both qualitative and quantitative techniques.

While there were no scandalous revelations here; it was super interesting to get an insight into the negotiation process which typically follows an attack. While it is heartening to know that ransomware teams also struggle to find the optimum price to capture consumer surplus, it's clear that on the current trajectory, ransomware as an enterprise remains profitable.

Ignoring the moral questions of paying ransoms, the paper includes both practical and strategic advice on how to proceed once a demand has been received. This reviewer was actually surprised by some findings, such as teaching staff to delay clicking on the ransom link (which would essentially start the timer on the negotiation) or making it clear that

the organisation does not have cyber insurance (since this raises the perverse incentive of demanding a higher payout).

TAKEAWAYS:

- ✓ Negotiations between ransomware crews and victims are more common than one would expect with crews often settling for one tenth of the original ransom (to avoid collecting \$0);
- ✓ Cyber crime insurance might actually work against companies that are then seen as guaranteed pay-days by crews that do their homework;
- ✓ A “how we got in”/vulnerability report sometimes accompanies the unlock keys and adds the cherry on top of a very odd relationship/transaction;
- ✓ Attackers often have access to the customer networks for weeks prior to the actual attack – early detection still matters.

Figure 17: An extract from the paper.

Take two examples, an organised cybercrime group that only hunts for big targets, asking for millions of dollars but only 5% of the victims paid. We compare this with another group which only asks for ten thousand dollars but 20% of the victims paid. Evidently, these two business strategies lead to different profit gains. Furthermore, the cost for operating a criminal operation should be included in the calculation. We use the following formula to calculate the overall profit from the adversary's perspective.

$$P = \sum_{i=1}^N (r_i * m_i * l_i) * f(i) - c_i$$

We describe P as the total profit taken by the criminal from N number of victims.

- r_i is the final ransomware demand on case.
- l_i is the percentage left after exchanging the cryptocurrency to “clean” currencies.
- m_i is the percentage left after paying the commission fee for the RaaS platform. This fee depends on the rules of the RaaS platform and the total ransom. It could cost from 10 to 30 percent of the total ransom. In some cases, this commission fee is 0 as some adversaries use in-house ransomware toolkits.
- $f(i)$ is the final decision made by the victim on whether to pay or not. It can either be 0 or 1, with 0 meaning the victim decided not to pay and 1 meaning the victim did pay.
- c_i is the cost of carrying out the attack. The detailed explanation can be found in the paper.



PRIVACY OF DNS-OVER-HTTPS: REQUIEM FOR A DREAM?

Authors: Levente Csikor, Himanshu Singh, Min Suk Kang, and Dinil Mon Divakaran



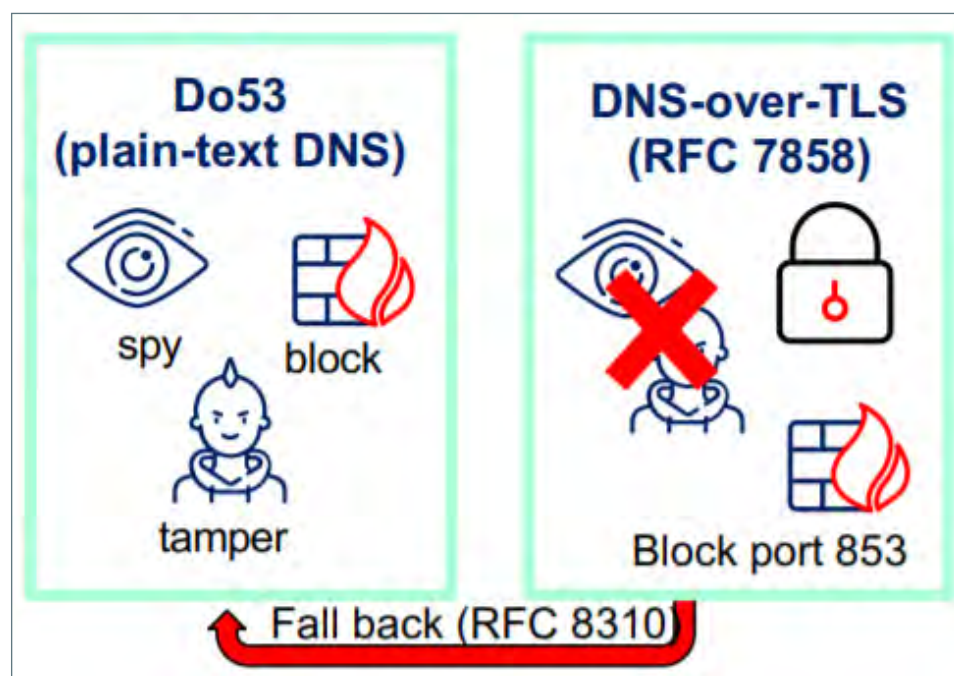
This research looked at the migration of DNS resolution from cleartext UDP DNS resolution (port 53), to DNS-over-TLS (port 853), to DNS-over-HTTPS (DoH; port 443). Noting that there are both benefits and drawbacks to DNS interception and monitoring, the research team explored using ML classification to detect and optionally block DoH requests, creating a fallback to UDP DNS requests. While there are legitimate use cases for DNS introspection and modification, ISPs, advertising agencies and nation-states regularly abuse their position of trust in the DNS resolution chain. DoH can cut out these unwanted third parties, however this research shows that HTTPS-wrapped DNS requests are detectable with over 90% confidence. Features for analysis included IP packet length, length of previous packet, and the timing between HTTPS packets – when these features were randomised,

padded, or normalised to recent non-DoH traffic, the same analysis was unable to correctly filter requests from HTTP web traffic.

TAKEAWAYS:

- ✓ While graceful degradation offers a pleasant user experience, security features should not be able to silently roll-back when presented with malicious activity.
- ✓ Despite three letter agencies' objections to the contrary, metadata or statistics about data really can have a significant security impact. As encrypted traffic grows, ISPs and large organisations will need to resort to increasingly statistical methods for monitoring and blocking bad traffic – providing a higher chance of DoS or blocking of legitimate content.

Figure 18: A figure showing how ISPs or organisations can degrade DNS-over-TLS to fall-back to legacy DNS allowing for monitoring or injection – and why DNS-over-HTTPS.



SLEIGHT OF ARM: DEMYSTIFYING INTEL HOUDINI

Author: Brian Hong



[View Slides](#)



[Watch Video](#)

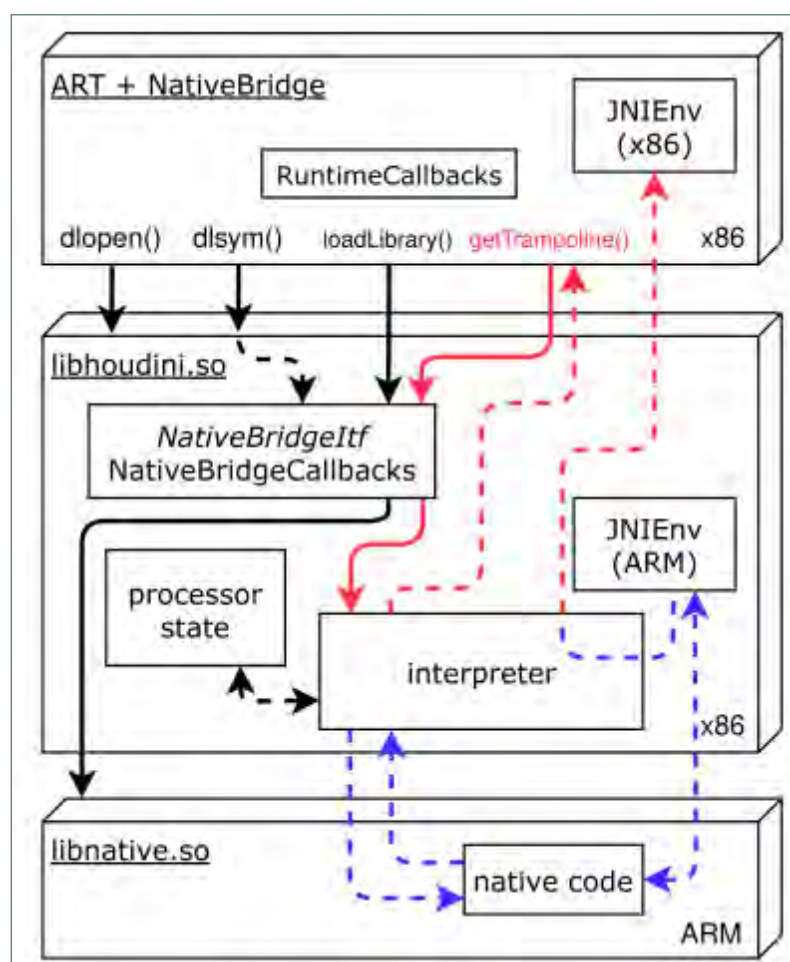
While Apple's Rosetta x86-to-ARM dynamic binary translator has been thrust into centre stage with the release of M1 ARM computers, Intel's ARM-to-x86 Houdini tool is less well known. Developed in conjunction with Google for supporting ARM Android applications on x86 hosts, Houdini supports hybrid Java and native applications typical of Android, and is the basis for Android support on x86 Chromebooks.

This research reverse engineered the Houdini libraries and explored the security implications of the hybrid ARM/x86 runtime environment. Most concerning is the shared memory space

between the two environments and the lack of a functioning no-execute bit (or other W^X page protections) for ARM code pages. Malicious code in the ARM world could write x86 code to an unprotected page and jump to it, or corrupt the x86 stack.

Finally, the author notes the possibility (hinted at [Differential analysis of x86-64 instruction decoders](#) from the [previous ThinkstScapes issue](#)) of building schizophrenic binaries. These would be applications that act benign on Houdini (presumably where Play Store submissions are vetted), but on actual ARM hardware express a more malicious personality.

Figure 19: A figure showing the flow of an ARM Android application executing JNI code on an x86 host.



TAKEAWAYS:

- ✓ As seen in the exploration of WebAssembly, it appears that industry-standard protections for exploitation mitigation are elided when ported to a new execution environment. Additional research into the instruction parsing is needed to determine the robustness of, and alignment between hardware and emulated environments.
- ✓ It is believed that Windows 11's support of Android applications is based on Houdini – thereby exposing the PC space to these security vulnerabilities.



Conclusion

Despite the ebbs and flows of the pandemic and the associated travel restrictions limiting in-person conferences with hallway tracks, there is still a wealth of top-notch research happening in the community.

EVEN OVER THE PERIOD OF A QUARTER, THERE WERE CLEAR THEMES THAT EMERGED IN THE PUBLISHED WORKS:

1. Clever techniques for putting servers to work
2. New tools for analysis and repair of software
3. AD and Azure revealing itself as a field of its own
4. Novel network architectures

With the holidays and the emergence of yet-another-variant, there is a sharp decline in conferences scheduled for Q1 2022, but hopefully researchers will return from their break refreshed and excited to tackle new challenges. We look forward to seeing what the community will be working on in 2022!

*A penguin on Boulders Beach, Cape Town, South Africa.
Photo by Kym Ellis on Unsplash.*



*Looking out from Cape Point, Cape Town, South Africa.
Photo by Clayton Cardinalli on Unsplash.*